

Incident Response Plan for a FinTech Startup in Nigeria

1. Purpose

This Incident Response Plan (IRP) provides a structured process for identifying, responding to, recovering from, and learning from security, operational, fraud, and service incidents affecting a Nigerian fintech startup.

The objective is to:

- Protect customer funds and data
 - Minimize service downtime
 - Meet regulatory obligations (CBN, NDPC, NIBSS, PCI DSS where applicable)
 - Maintain customer trust
 - Prevent panic-driven decision making common in startup environments
-

2. Scope

This plan applies to:

- Mobile application
 - Web application
 - APIs
 - Payment gateway integrations
 - Banking integrations
 - Card processing
 - Wallet system
 - KYC services
 - Internal administration systems
 - Cloud infrastructure
 - Third-party vendors
-

3. Incident Severity Levels

Severity	Description	Example	Response Time
P1 (Critical)	Customer funds at risk or complete outage	Wallet balance corruption, payment failures nationwide	Immediate
P2 (High)	Major feature unavailable	Transfers failing, KYC unavailable	Within 15 min

P3 (Medium)	Limited functionality	Notification delays	Within 1 hour
P4 (Low)	Cosmetic or isolated issue	UI bugs	Next sprint

4. Incident Response Team

Instead of traditional departments, startups should assign responsibilities according to MVP feature ownership.

Role	Responsibilities
Incident Commander	Coordinates response, assigns tasks, approves communications
Payments Lead	Payment APIs, NIBSS, transfers, reconciliation
Wallet Lead	Ledger integrity, balances, credits/debits
Authentication Lead	Login, OTP, MFA, account security
Mobile Lead	Android/iOS client issues
Backend Lead	APIs, databases, infrastructure
DevOps/SRE	Cloud, monitoring, rollback, deployments
Security Lead	Threat investigation, malware, compromised accounts
Customer Support Lead	Customer communication and ticket management
Compliance Officer	CBN, NDPC, regulator reporting
Executive Sponsor (CEO/CTO)	Business decisions, external communications

5. Incident Lifecycle

Detect

↓

Assess

↓

Declare Incident

↓

Assign Commander

↓

Contain

↓

Investigate

↓

Recover

↓

Validate

↓

Close

↓

Postmortem

6. Communication Rules

Internal

Single source of truth:

- Incident Slack/Teams channel

- Shared incident document
- No private side discussions

Status updates:

- Every 15 minutes (P1)
- Every 30 minutes (P2)

External

Only designated spokespersons communicate externally.

Possible stakeholders:

- Customers
- Partner banks
- NIBSS
- Payment providers
- CBN (where required)
- Media (if necessary)

Never speculate.

Only communicate verified facts.

7. Startup Anti-Panic Rules

During incidents:

DO

- Stop new deployments
- Assign one Incident Commander
- Record all actions
- Roll back known bad releases
- Protect customer funds before restoring convenience

DO NOT

- Push multiple fixes simultaneously
 - Change databases manually without approval
 - Allow everyone to investigate independently
 - Restart all services blindly
 - Guess root causes publicly
-

8. Core MVP Feature Playbooks

Playbook 1 – Login Failure

Indicators

- Users cannot login
- OTP not delivered
- Authentication timeout

Immediate Actions

1. Confirm issue using monitoring.
2. Check authentication service.
3. Verify SMS provider.
4. Roll back latest deployment.
5. Switch to backup OTP provider.

Recovery

- Restore authentication.
 - Validate successful login.
 - Monitor for one hour.
-

Playbook 2 – Transfer Failure

Indicators

- Pending transfers
- NIBSS timeout API
- failures

Actions

1. Pause retries.
2. Verify NIBSS connectivity.
3. Review settlement queues.
4. Prevent duplicate transfers.
5. Reconcile transactions.

Recovery is complete only after ledger reconciliation.

Playbook 3 – Wallet Balance Mismatch

Critical Priority (P1)

Immediate Response

Freeze:

- Withdrawals
- Internal transfers Automated
- settlement

Do NOT modify balances manually.

Investigation

- Compare ledger
- Database
- Event logs
- Payment records

Recovery only after full reconciliation.

Playbook 4 – Payment Gateway Outage

Actions

- Verify provider status
 - Switch provider if available
 - Queue payments safely
 - Notify customers
-

Playbook 5 – Database Failure

Immediate Actions

- Activate standby database
 - Restore latest backup if necessary
 - Verify data integrity
 - Enable read-only mode if appropriate
-

Playbook 6 – Cloud Infrastructure Failure

Checklist

- Check monitoring
 - Verify DNS
 - Verify load balancer
 - Scale infrastructure
 - Restore from Infrastructure as Code
 - Roll back deployment
-

Playbook 7 – Security Breach

Indicators

- Unauthorized access
- Data exfiltration
- Suspicious admin activity

Immediate Actions

- Isolate systems
- Rotate secrets
- Disable compromised accounts
- Preserve logs
- Notify leadership

Recovery

- Patch vulnerability
 - Restore secure environment
 - Conduct forensic review
-

Playbook 8 – Fraud Incident

Examples

- Account takeover
- SIM swap
- Multiple failed logins Fake transfers

Actions

- Suspend affected accounts
- Increase fraud monitoring
- Review transaction history
- Notify customer
- Escalate to compliance

9. Incident Timeline Template

Time	Action	Owner
09:00	Incident detected	Monitoring
09:05	Incident declared	Commander
09:10	Engineering assigned	Backend Lead
09:20	Root cause identified	Investigation Team
09:35	Rollback completed	DevOps
09:45	Service restored	Commander
10:30	Monitoring stable	SRE
Next Day	Postmortem	Entire Team

10. Incident Report Template

Incident ID

INC-YYYYMMDD-001

Summary

Brief description of the incident.

Severity

P1 / P2 / P3 / P4

Impact

- Customers affected
- Transactions affected
- Downtime
- Financial impact

Timeline

Chronological list of key events.

Root Cause

Technical explanation of what failed.

Contributing Factors

Examples:

- Poor monitoring
- Missing tests
- Human error
- Third-party outage

Resolution

Steps taken to restore service.

Customer Communication

Messages sent, channels used, and timing.

Regulatory Notifications

Record any notifications made to:

- Central Bank of Nigeria (CBN)
 - Nigeria Inter-Bank Settlement System (NIBSS)
 - Nigeria Data Protection Commission (NDPC)
 - Other relevant partners or regulators
-

Lessons Learned

What should change to prevent recurrence?

Action Items

Task	Owner	Due Date	Status
Improve monitoring	DevOps	DD/MM/YYYY	Open
Add reconciliation test	Backend	DD/MM/YYYY	Open
Update runbook	Security	DD/MM/YYYY	Open

11. Metrics to Track

- Mean Time to Detect (MTTD)
 - Mean Time to Acknowledge (MTTA)
 - Mean Time to Recover (MTTR)
 - Number of customer-impacting incidents
 - Failed deployment rate
 - Rollback frequency
 - Payment success rate
 - Transfer reconciliation accuracy
 - Fraud detection rate
 - Customer support response time
-

12. Post-Incident Review

Conduct a blameless postmortem within 48 hours for all P1 and P2 incidents. The review should answer:

1. What happened?
 2. What was the customer impact?
 3. How was the incident detected?
 4. What was the root cause?
 5. What went well during the response?
 6. What did not go well?
 7. Which safeguards failed?
 8. What preventive actions will be implemented?
 9. Who owns each follow-up action?
 10. What deadlines have been agreed?
-

13. Nigeria-Specific Considerations

For a fintech operating in Nigeria, incident response should also account for:

- Maintaining transaction reconciliation with NIBSS and partner banks after outages.
- Meeting applicable reporting obligations under Central Bank of Nigeria (CBN) regulations and the Nigeria Data Protection Act (NDPA) where customer data is affected.
- Managing dependencies on local telecom providers for OTP and SMS delivery, with fallback providers where possible.
- Accounting for power and internet disruptions by using redundant cloud regions, automated backups, and disaster recovery procedures.
- Preparing customer communications in clear language that reassures users about the safety of their funds while investigations are ongoing, avoiding speculation until facts are verified.

This plan emphasizes structured ownership by MVP feature, disciplined communications, and predefined playbooks to reduce the "startup panic" that often prolongs outages and increases customer impact.